

ПРОДУКТ №3 · РОБИМО ЗАРАЗ

«Approve-on-phone» SCA / Transaction-Signing SDK

ГОТОВЕ РІШЕННЯ · ПРУФ
БЕЗПЕКИ

Мобільна строга автентифікація і підпис транзакцій банківського рівня: QR/push → біометрія → ECDSA-підпис у Secure Enclave. Беремо власне готове рішення (MOL) і подаємо схемами та як технічне рішення — закриває «security gap» у розмовах із банками по Продукту №1.

Чому це і чому зараз

- **Регуляторний драйвер.** PSD3/PSR — політгода 27.11.2025, публікація ~Q2 2026: розширена відповідальність PSP за фрод, name-to-IBAN matching, посилення SCA. CBUAE заборонив SMS OTP як єдиний метод (дедлайн 31.03.2026).
- **Роль продукту.** Не showcase-зірка і не великий revenue, а **credibility/безпековий пруф** — доказує, що нам можна довірити гроші. Плюс стабільна нішева виручка.
- **Конкуренція — чесно.** Ринок зрілий і домінований (OneSpan/Cronto, Thales, RSA, Entrust, IDEMIA). Бар'єр — довіра/сертифікація, не технологія.
- **Зсув від SMS OTP.** SMS OTP визнано небезпечним; ринок рухається до on-device криптографії / passkeys. Банкам потрібна заміна — це наш вхід.
- **Наша база.** Готове рішення з MOL: ECDSA P-256 у Secure Enclave, push-апрув, anti-jailbreak, key-wipe при lockout. Беремо готове — показуємо схемами і як технічне рішення.
- **Наш кут.** Lightweight embeddable для SME-fintech / бірж / необанків, для яких OneSpan/Thales надмірні. Сертифікація — передумова продажу (roadmap).

Три технічні компоненти

КОМПОНЕНТ 1

On-device ключ і підпис

Генерація ECDSA P-256 у Secure Enclave (iOS) / Keystore+StrongBox (Android); приватний ключ не залишає пристрій; підпис лише за user-presence (біометрія/PIN).

КОМПОНЕНТ 2

Push-апрув + dynamic linking

Сервер шле деталі транзакції → користувач переглядає на телефоні → біометрія → підпис прив'язує суму+отримувача (PSD2 dynamic linking). Заміна SMS OTP.

КОМПОНЕНТ 3

Цілісність пристрою + anti-fraud

Root/jailbreak detection, anti-tampering/hooks, device binding/attestation, захист від replay (nonce/timestamp), PIN-lockout → key wipe.

Схема продукту



Банк ініціює транзакцію → push на телефон → SCA SDK (показ деталей · біометрія · підпис у Secure Enclave) → банк верифікує підпис (dynamic linking) → виконання.

Базові вимоги

Криптографія на пристрої: генерація ECDSA P-256 у Secure Enclave (iOS) / Keystore+StrongBox (Android); приватний ключ не експортується; підпис лише за обов'язкового user-presence.

Push-апрув і UX: out-of-band доставка челенджу; чіткий показ деталей транзакції; біометрія/PIN; fallback-логіка; підтримка iOS/Android.

Серверна верифікація і lifecycle: реєстрація pub-key (enroll); верифікація підпису; rotate/revoke ключів; audit-логи; інтеграційні endpoints.

Підпис і dynamic linking: підпис прив'язує суму+отримувача (PSD2); challenge-response із сервером; захист від replay (nonce/timestamp); канонічна серіалізація даних транзакції.

Цілісність пристрою: root/jailbreak detection; anti-tampering/hooks; device binding/attestation; PIN-lockout → key wipe; виявлення емуляторів.

Інтеграція / деплой: SDK (iOS/Android) embeddable у наявний апп банку; серверні endpoints; OS-вимоги; сертифікація (напр. під PSD2 SCA) — як roadmap, не у v1.